

Introduction à Burp Suite pour le Pentest

Club Info INSA Toulouse

27 mars 2025

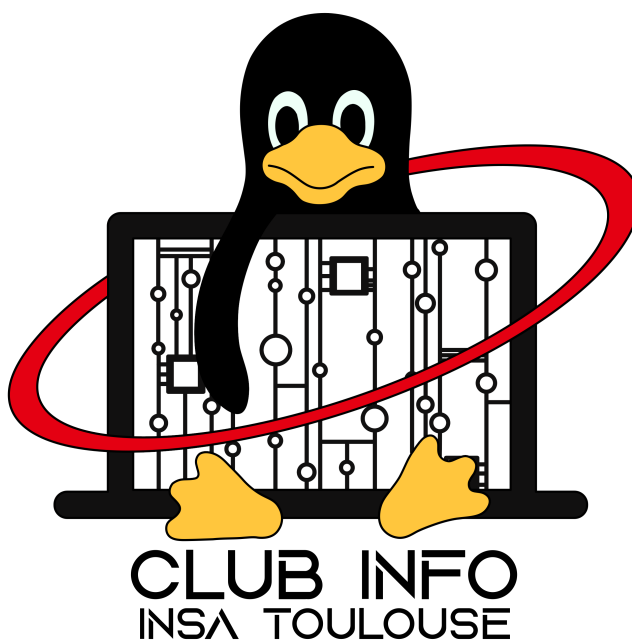
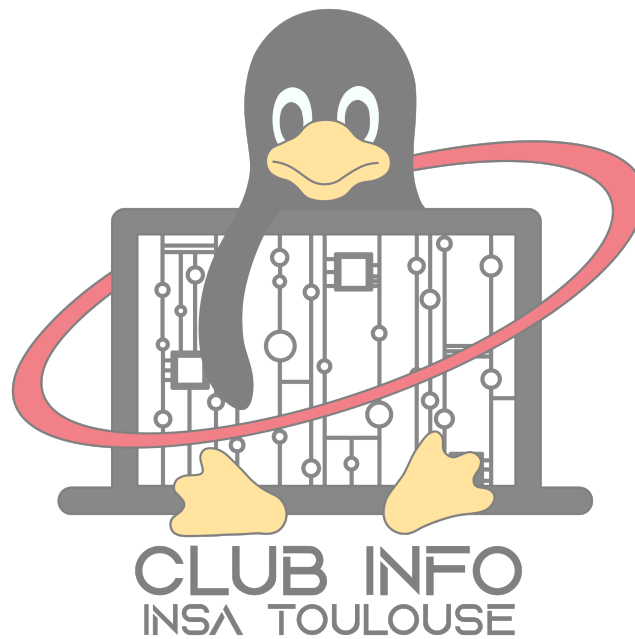
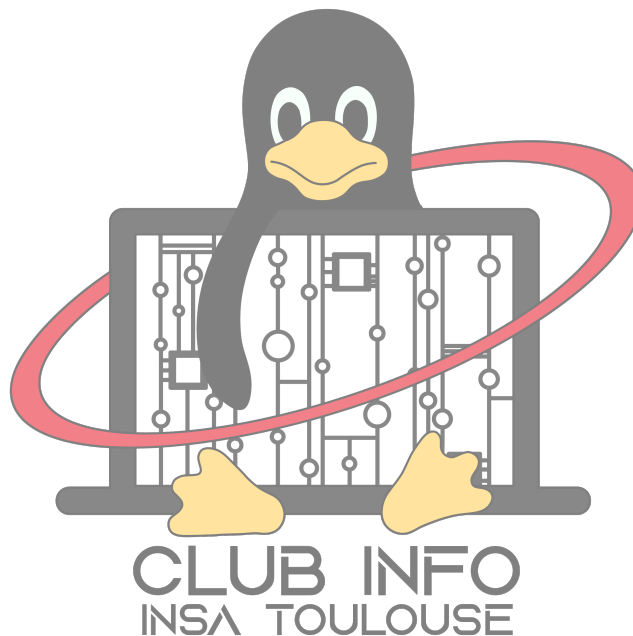


Table des matières



Lexique

- **Proxy** : Un serveur intermédiaire entre le client et le serveur cible, utilisé pour intercepter et modifier les requêtes.
- **Intercept** : Fonctionnalité permettant de capturer et modifier les requêtes HTTP en temps réel.
- **Spider** : Outil permettant de cartographier automatiquement un site web.
- **Intruder** : Module utilisé pour tester des attaques automatisées, comme le brute force.
- **Repeater** : Permet de rejouer et modifier des requêtes HTTP pour observer les différences de réponse.
- **Collaborator** : Outil avancé de Burp Suite pour détecter des failles nécessitant une interaction externe.
- **Extender** : Module permettant d'ajouter des extensions personnalisées à Burp Suite.
- **BApp Store** : Boutique d'extensions proposant des plugins pour améliorer les fonctionnalités de Burp Suite.



1 Introduction

Burp Suite est un outil essentiel pour les pentesteurs et les chercheurs en cybersécurité. Il permet d'analyser, manipuler et tester les applications web en interceptant le trafic HTTP/S et en automatisant certaines attaques. Ce document présente les fonctionnalités principales de Burp Suite pour les débutants.

2 Installation et Configuration

2.1 Téléchargement et Installation

Burp Suite est disponible en plusieurs éditions : Community (gratuite), Professional et Enterprise. Pour l'installer :

1. Télécharger Burp Suite sur <https://portswigger.net/burp>.
2. Exécuter l'installateur correspondant à votre système d'exploitation.
3. Lancer Burp Suite et choisir la version souhaitée.

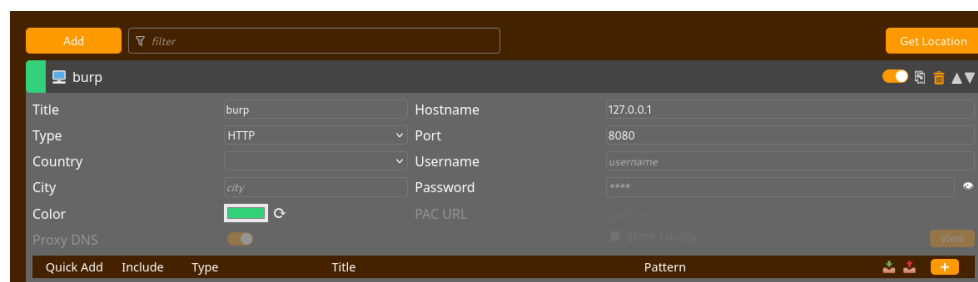
2.2 Configuration du Proxy

Burp Suite intercepte le trafic web via un proxy local. Pour le configurer :

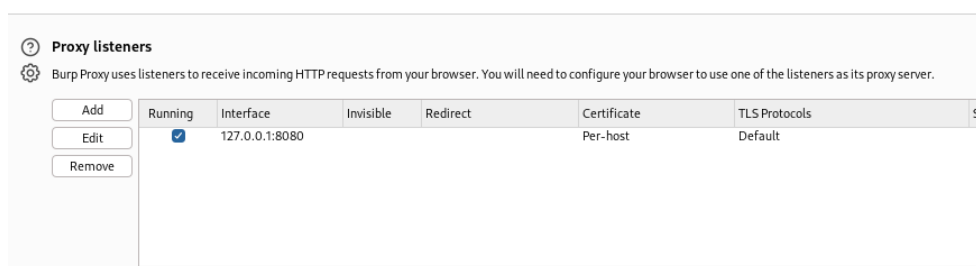
1. Aller dans **Proxy > Options**.
2. Vérifier que le proxy écoute sur `127.0.0.1:8080`.
3. Configurer le navigateur pour utiliser ce proxy (exemple : Firefox, Chrome avec l'extension FoxyProxy).
4. Configurer le proxy dans burpsuite.

2.3 Tutoriel Configuration du proxy (avec FoxyProxy sous Firefox)

1. Aller dans **extension > Manage extension**.
2. Dans la barre de recherche, chercher "FoxyProxy".
3. Une fois trouvée, installer l'extension, l'ouvrir puis créer un nouveau proxy avec les paramètres suivants (ATTENTION LORSQUE VOUS VOUDREZ UTILISER BURP PAR LA SUITE LE PROXY DEVRA ÊTRE ACTIVÉ) :



4. Configurer le proxy dans burpsuite



3 Interception et Modification des Requêtes

3.1 Utilisation de l'Intercept

Burp permet d'intercepter et modifier les requêtes HTTP avant qu'elles n'atteignent le serveur cible :

1. Activer **Intercept** is on dans l'onglet **Proxy**.
2. Capturer une requête et l'examiner.
3. Modifier ses paramètres (exemple : changer un identifiant ou ajouter un en-tête personnalisé).
4. Envoyer la requête modifiée au serveur.

4 Utilisation de l'Intruder et du Repeater

4.1 Intruder : Automatisation des Attaques

L'outil **Intruder** permet d'automatiser des attaques en envoyant plusieurs requêtes avec des paramètres variables.

1. Aller dans l'onglet **Intruder**.
2. Charger une requête depuis l'historique de Burp.
3. Définir les positions des variables à tester (exemple : nom d'utilisateur dans un formulaire de connexion).
4. Choisir une liste de valeurs à tester (exemple : une wordlist pour du brute force).
5. Lancer l'attaque et analyser les résultats.

4.2 Repeater : Tests Manuels de Requêtes

L'outil **Repeater** permet d'envoyer des requêtes modifiées manuellement et d'observer les réponses du serveur.

1. Envoyer une requête depuis l'historique de Burp vers **Repeater**.
2. Modifier les paramètres de la requête (exemple : changer un cookie d'authentification).
3. Envoyer la requête et observer la réponse.
4. Comparer les différences de comportement pour identifier des vulnérabilités.

5 Personnalisation avec Extender et le BApp Store

5.1 Utilisation du module Extender

Extender permet d'ajouter des extensions pour améliorer les fonctionnalités de Burp Suite. Ces extensions peuvent être créées en Java, Python ou Ruby.

5.2 Installation d'extensions via le BApp Store

Burp Suite propose une boutique d'extensions, le **BApp Store**, qui permet d'ajouter des plugins communautaires et officiels :

1. Aller dans **Extender** > **BApp Store**.
2. Rechercher une extension (exemple : "Auth Analyzer" pour tester les problèmes d'authentification).
3. Installer l'extension et redémarrer Burp si nécessaire.

